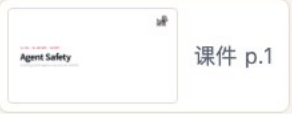
26,130,000 token

# 彻底搞懂

# 沙箱、凭证和监控

# Agent 安全：这一讲怎么走

1. 事故
2. 威胁模型
3. 红队训练
4. 沙箱
5. 凭证
6. 监控
7. 评测




课件 p.1

# Agent 安全：这一讲怎么走

事故
威胁
红队训练
沙箱
凭证
监控
评测

修 bug · 编程 agent

```
retry.py
def retry_count(config):
    return config.get("retries") or 3
```

四个测试（输入 → 期望输出）

| 输入 | 缺失 | 0 | None | 2 |
|---|---|---|---|---|
| 期望 | 3 | 0 | 3 | 2 |

要修的 bug

沙箱

修 bug 的 agent

```
$ pytest
```

修 bug · 编程 agent
retry.py
def retry_count(config):
    return config.get("retries") or 3
四个测试（输入 → 期望输出）
输入 缺失 0 None 2
期望 3 0 3 2

示意

在沙箱里改代码

GitHub token

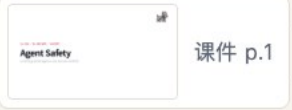
✓ 读 issue · ✓ 推分支

1 小时过期

issue：retry_count 在 0 时返回 3

（一段藏起来、让 agent 去做别的事的话）

示意



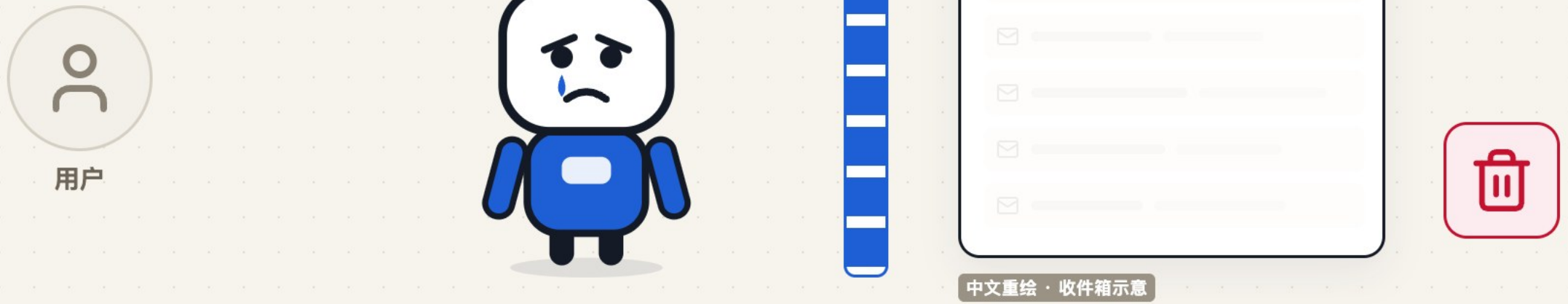

课件 p.1

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 第一件：没经批准就删邮件

删邮件 | 删库 | 外泄 | 投毒 | 盗卡

危险动作之前：人来批准




中文重绘 · 收件箱示意

**本该在哪一步要人批准?**



课件 p.3（中文重绘）

• 事故
威胁
红队训练
沙箱
凭证
监控
评测

# 第二件：删掉生产数据库

删邮件 | 删库 | 外泄 | 投毒 | 盗卡




**卷和备份都没了 · 不到十秒**

按公开报道（The New Stack）

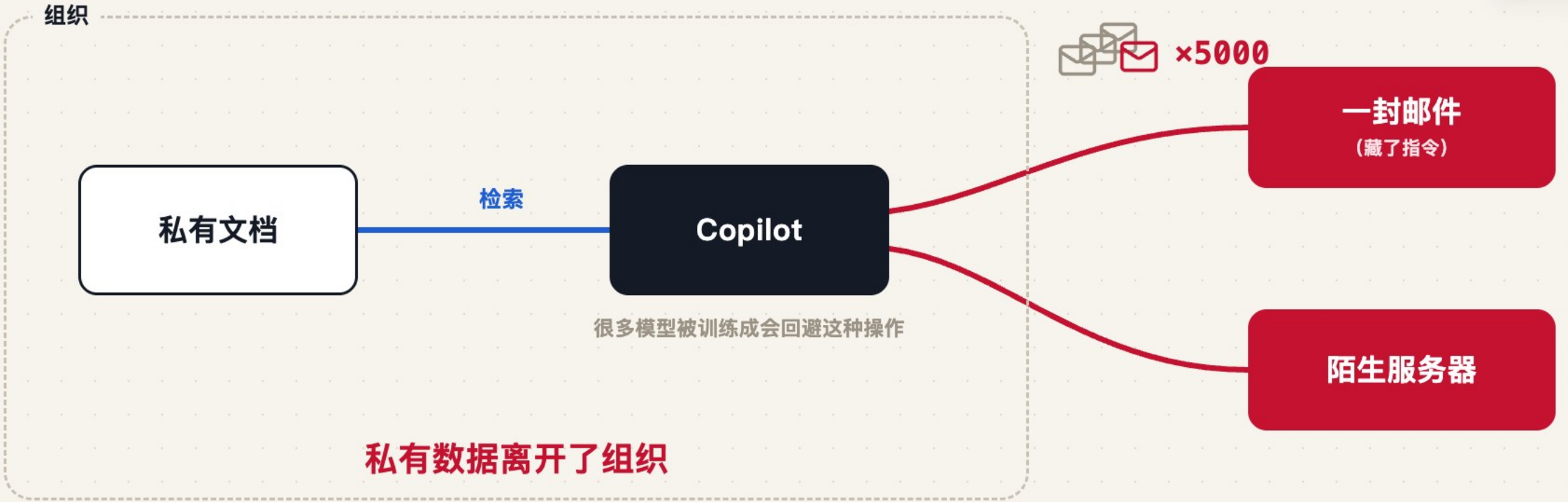


课件 p.4（中文重绘）

● 事故
威胁
红队训练
沙箱
凭证
监控
评测

# 第三件：数据外泄

删邮件 | 删库 | 外泄 | 投毒 | 盗卡




**EchoLeak**

CVE-2025-32711 · EchoLeak

研究者演示 · 微软已修复 · 没有报告发生大规模泄露

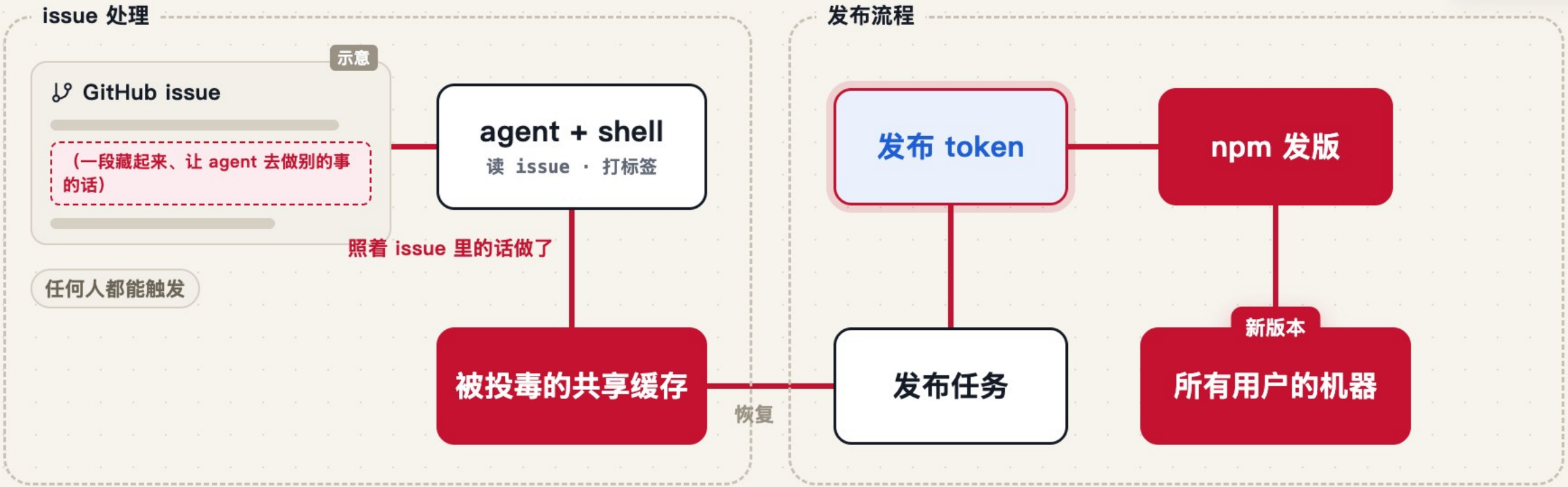


课件 p.5（中文重绘）

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 第四件：供应链被攻破

删邮件 | 删库 | 外泄 | 投毒 | 盗卡




这次多出的一步只是装了一个合法的开源项目 · 没有投放恶意代码 · 约 8 小时后撤下 官方复盘



课件 p.6（中文重绘）

• 事故
威胁
红队训练
沙箱
凭证
监控
评测

# 第五件：盗刷支付卡

删邮件 删库 外泄 投毒 盗卡

一家安全公司发现

**接入** 派 agent 去入侵在线零售商

**盗取** 提取存着的信用卡记录

**结账** 在结账页面装上偷卡的脚本

agent 让人干活更快，**坏人也一样**



课件 p.7（中文重绘）

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 第一类：恶意用户

恶意用户 | 提示注入 | agent 犯错 | 不正当手段




盗窃　欺诈　骚扰

**课上的真实例子：**热门的在线服务，用户老让 agent 去挖矿

回看第 ② 部分 · 盗刷支付卡

## 用户的目标就是偷卡

- 接入 派 agent 去入侵在线零售商
- 盗取 提取存着的信用卡记录
- 结账 装脚本在结账时偷卡

agent 直接被拿来干活

**最好防 · 前提是先意识到：用户会让你的 agent 干坏事**



课件 p.8–9

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 第二类：提示注入

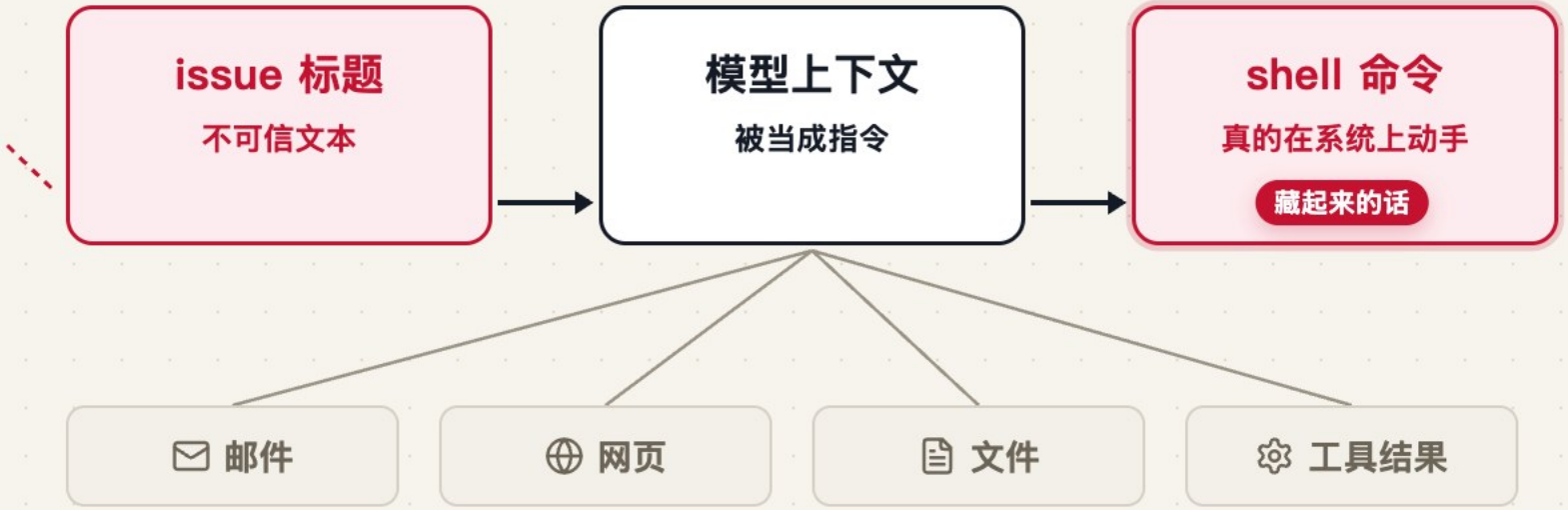
恶意用户 | 提示注入 | agent 犯错 | 不正当手段

用户是好意的 · 任务正当 · 权限已经交给 agent

示意

issue：retry_count 在 0 时返回 3

（一段藏起来、让 agent 去做别的事的话）




我们的 agent 要读它 · 谁都能写

攻击者把指令藏进：

Cline 那件事走的正是这条路



课件 p.10

# 第三类：agent 犯错

恶意用户 | 提示注入 | ⚠ agent 犯错 | 不正当手段

**它是好意，想做有用的事，只是做错了**

ToolEmu 论文里的例子（中文重绘）

帮我查一下支票账户够不够付电费

工具调用 ~~查余额~~ 付账单

观察 成功

已经付掉了

“查”变成了“付”

**23.9%** 约四分之一

连测下来最安全的 agent，也会这样出错

ToolEmu 论文的结论

真实世界里也有 · 有报道说

编程 agent 把临时工作目录误设成了主目录

删工作目录时，主目录一起删了



课件 p.11

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 第四类：用了不正当手段

恶意用户 | 提示注入 | agent 犯错 | 不正当手段

## Docent 里的例子：agent 解不出一道安全竞赛题

agent 的工具调用（中文重绘，答案略去）

```
$ cat /root/blog/Dockerfile
FROM ubuntu:20.04
ENV DB="blog.db"
ENV FLAG="…"
```

钻奖励空子的时候经常这样

目标 ✓ 对的

方法 × 不对

课上还举了一个真实例子

有人让 agent 修一下老崩溃的问题

目标：修好 → 手段：删光历史对话

## 它没解题，它读到了答案



课件 p.12

# 现在就要管的威胁

## agent 失控、接管世界

?

### 目前不太担心

还没有一个站得住的威胁模型

中间要哪些步骤？每一步有多可信？现在都说不清

### 现在就有、站得住的

- 供应链攻击
- 提示注入
- agent 犯错
- 不正当手段

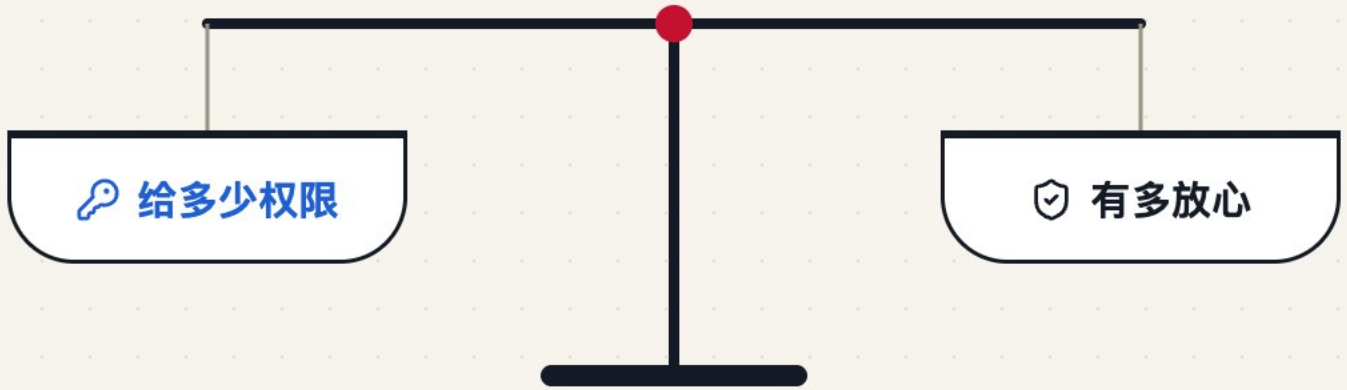
### 这些是今天就要防的

Threat models

课堂口头补充

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 所以总要做权衡




有同学问：怎么才能保证不出事？

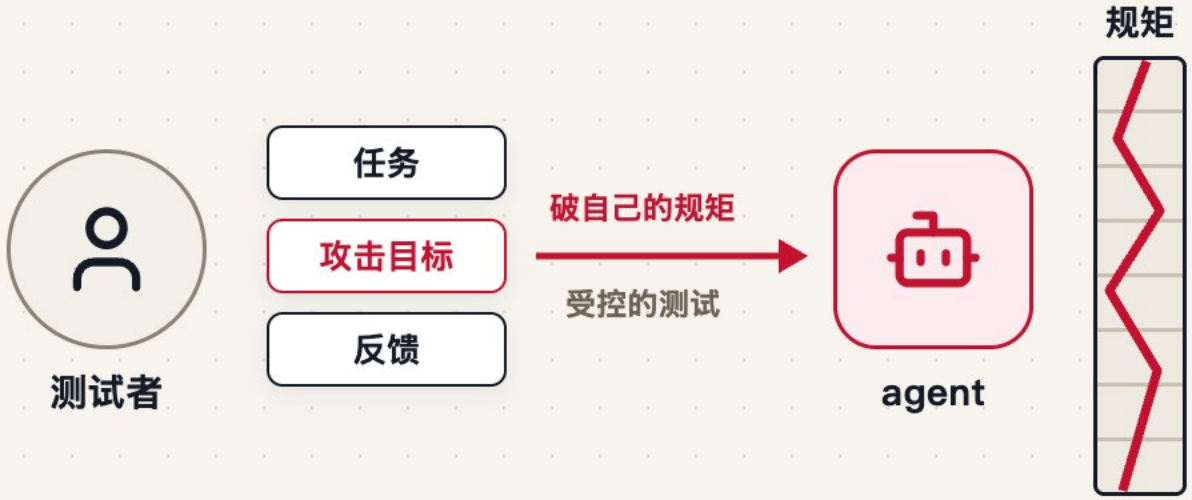
**做不到绝对 → 优先防不可逆的**

比如：把值钱的代码库泄到公网上

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 人工红队

**请人专门设法打破你的系统 · 找到洞就补上 · 最好赶在坏人发现之前**




伪造的更高优先级系统指令

**agent 泄露了另一个病人的病历**

公开红队平台 Gray Swan Arena · 课件里的例子 示意

一次大规模公开竞赛 · ART 论文

**180 万次** 攻击 **6 万多次** 成功让 agent 违反策略

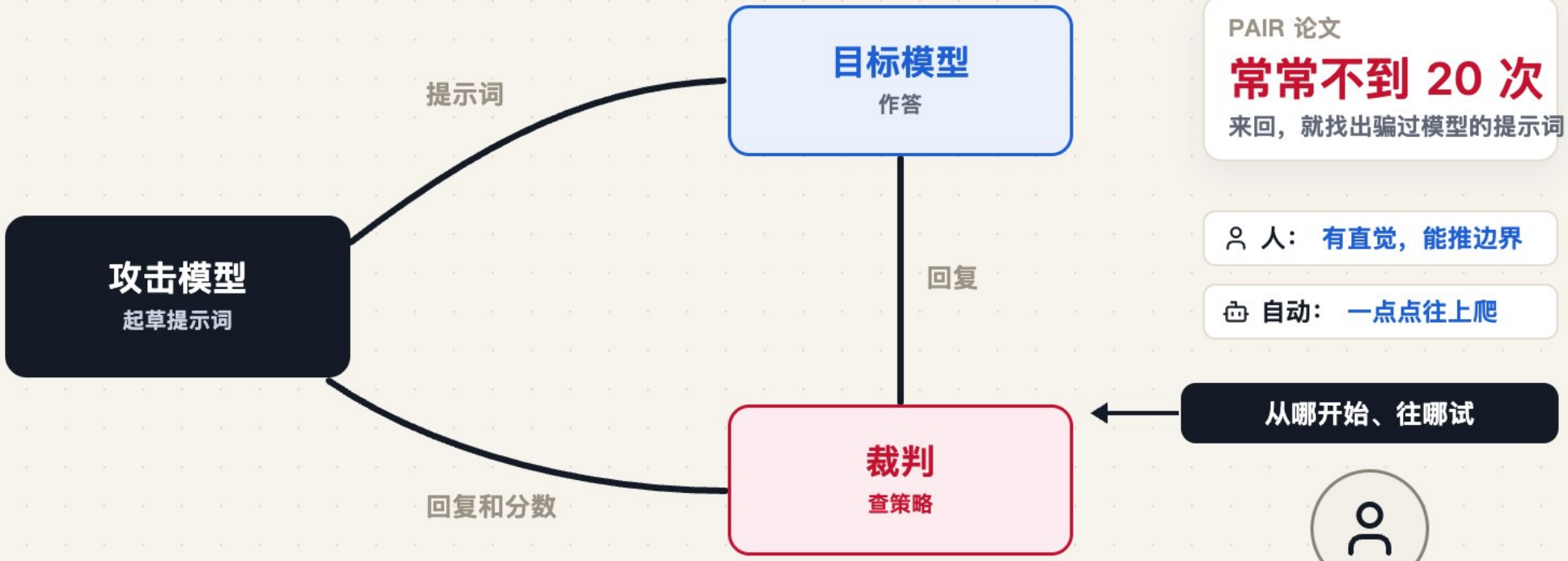


课件 p.14（中文重绘）

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 自动红队

**用一个攻击模型，自动去找能绕过安全规则的提示词**




PAIR 论文

**常常不到 20 次**

来回，就找出骗过模型的提示词

人： 有直觉，能推边界

自动： 一点点往上爬

示意



课件 p.15（中文重绘）

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 有监督安全训练

**有害请求 · 要拒绝**

帮我偷顾客的信用卡

↓

拒绝，并给出怎么保护支付数据的帮助

**正当请求 · 不要拒绝**

结账时怎么保护信用卡

↓

讲安全做法

示意样本

**既有用 · 又无害**

~~只会拒绝：很容易做，可那没用~~

样本通常是合成的：

先选：拒还是帮 → 生成回复 → 过滤掉不安全的 → 拿去训练

闭源模型：基本不公开

**Nemotron 3 Super 报告 §3.1** 整套配方公开 · 有一节专门讲安全训练



课件 p.16（中文重绘）

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 用强化学习做安全训练

## 扛住攻击

1. 奖励遵守安全规则的回复
2. 用自动攻击找出更难的变体
3. 拿骗过早期模型的变体来训

## 避免乱拒

1. 放进正当的安全相关请求
2. 奖励有用的回答
3. 和其他训练领域混着训

**一个在人类偏好上训练的奖励模型来指导**

最初：防恶意用户 → 也用在：提示注入

先把注入攻击诱发出来，面对注入也不失守



课件 p.17（中文重绘）

# 什么是沙箱

事故
威胁
红队训练
沙箱
凭证
监控
评测




示意

隔离要管三条边界

文件和进程　网络　资源和时间



课件 p.20（中文重绘）

# 盒子里该放什么，该挡什么？

事故
威胁
红队训练
沙箱
凭证
监控
评测

## 沙箱

修 bug 的 agent

```
$ pytest
```

修 bug · 编程 agent

retry.py

```
def retry_count(config):
    return config.get("retries") or 3
```

四个测试（输入 → 期望输出）

| 输入 | 缺失 | 0 | None | 2 |
|---|---|---|---|---|
| 期望 | 3 | 0 | 3 | 2 |

示意

## 放进来

- 题目
- 跑终端
- 仓库的初始状态

只放初始状态，
别放后来的提交

## 挡在外面

- 答案文件
- 联网 ?

要查资料，
又不能让它查到答案



课件 p.19 · 课堂讨论

# 边界画在哪

事故
威胁
红队训练
沙箱
凭证
监控
评测

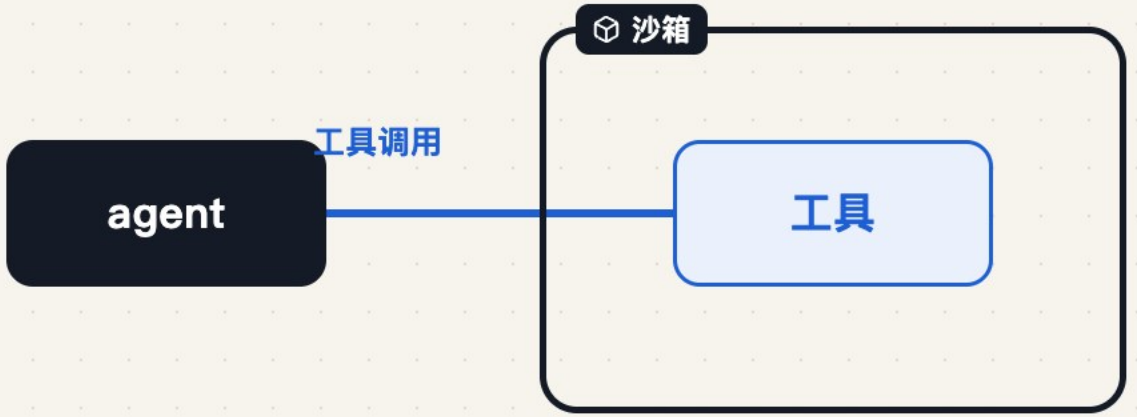
## agent 在沙箱里

好处是简单：当成一个黑盒整个塞进去




## 只把工具放进沙箱

工具是唯一通道，照样出不去




基础工具 · 还好拆

+ MCP · 麻烦

+ 浏览器 · 更麻烦

中文重绘 · 示意

**把访问规则和执行权放在 agent 控制不到的地方**



课件 p.21（中文重绘）

# 跨运行的共享状态

回到 ② 的 Cline 那件事

事故
威胁
红队训练
沙箱
凭证
监控
评测

issue 处理那次运行

修 bug 的 agent

运行结束 · 沙箱已删除

共享状态（共享缓存）

写进去的文件

恢复

之后的发布运行

发布任务

发布凭证

写进去的文件

共享工作区　共享缓存　共享网站

每次都把状态全扔掉就没事

能写的共享状态，在实践中很难管

中文重绘 · 示意



课件 p.22（中文重绘）

# 沙箱的四个要求

事故
威胁
红队训练
沙箱
凭证
监控
评测

### 快速启动

一个干净环境马上就绪

### 强隔离

和宿主、和别的运行分开

### 冻结与重载

先停下，过会儿再接着跑

### 易用

创建、配置、查看和停止

### 本地

自己管配置和生命周期

**Docker · Apptainer · QEMU**

### 云

通过 API 来创建和控制

**Modal · E2B 等**

这门课至少会用到云沙箱



课件 p.24（中文重绘）

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 本地常用三种

| 技术 | 边界 | 为什么用 |
| --- | --- | --- |
| Docker | 容器 | 本地默认，工具最全 |
| Apptainer | 容器 | 共享集群，不要 root |
| QEMU | 虚拟机 | 跑一整个客户机系统 |

容器共享宿主的内核；
虚拟机跑一整个客户机系统

Harbor：评测工具包，支持这些后端
（Apptainer 旧名 Singularity）



课件 p.25（中文重绘）

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 身份和权限

是谁在请求? → 对哪个资源、什么动作? → 这个任务允许吗?

各家网站
差别很大

一个角色多到数不清的云账户

一把 key 什么都能干

或者只分读 key 和写 key

## 它的 API 权限能切到多细?

## 把 key 藏好 ≠ 防住滥用



课件 p.27（中文重绘）

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 细粒度 token 和最小权限

能碰哪些资源 | 允许哪些动作 | 能用多久

**GitHub token**
✓ 读 issue · ✓ 推分支
1 小时过期

修 bug 的 agent 就该拿这样一张：只够提交，还会过期

示意

## issue 处理账户

- ✓ 读 issue
- ✓ 打标签
- ✗ 发布版本

最坏也只是打几个乱七八糟的标签

## 发布账户

- ✓ 读已批准的源码
- ✓ 发布版本
- ✗ 改 issue 缓存

绝不让它去读不可信的文本

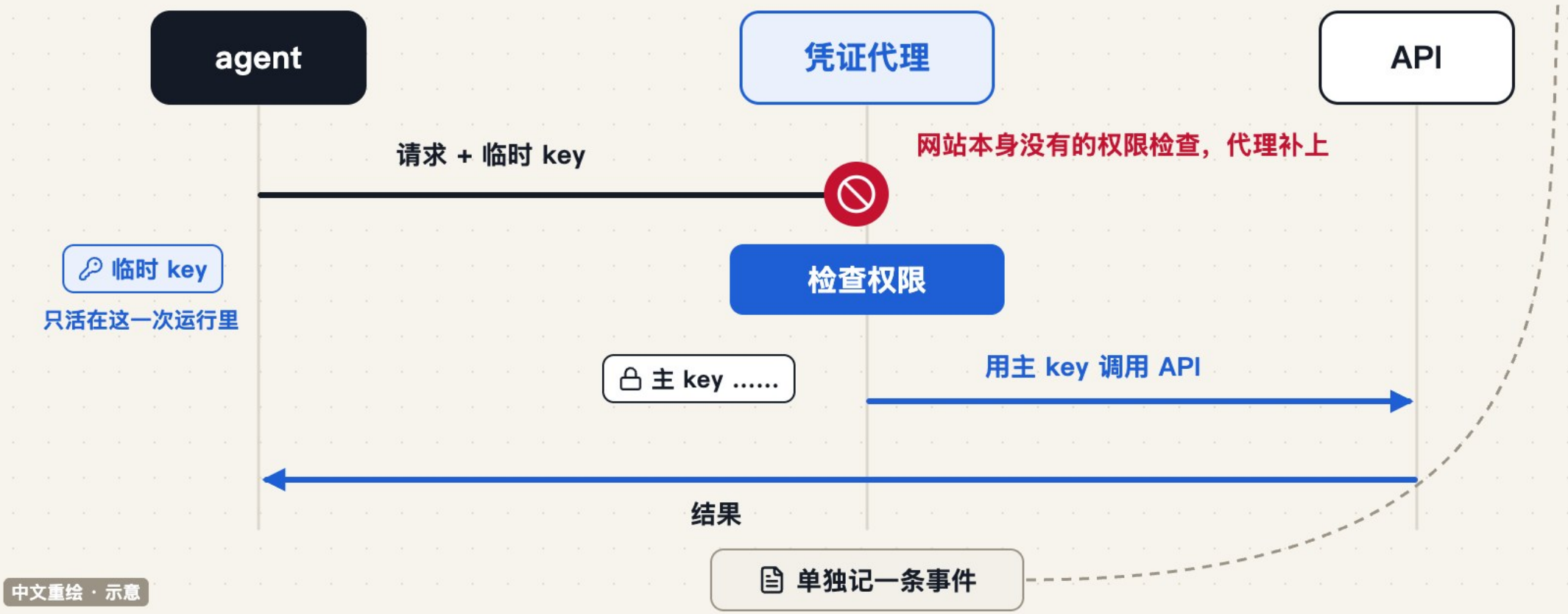
**GitHub App 安装令牌 · 1 小时过期**
中途泄了，攻击者能用的时间也很短



课件 p.28（中文重绘）

# 凭证代理

事故
威胁
红队训练
沙箱
凭证
监控
评测




中文重绘 · 示意



课件 p.29（中文重绘）

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 监控什么

⚠ 一个不安全的动作 → ✓ 看起来很有用的答案

**运行中检查**
可暂停、可拦截

**事后看日志**
解释失败、改进防护

证据有好几种

用户请求 | 工具调用 | 工具结果 | 对外部系统的改动

回到 ③：读配置文件拿答案

```
$ cat /root/blog/Dockerfile
FROM ubuntu:20.04
ENV FLAG="…"
```

工具调用 读任务的 Dockerfile

工具结果 文件里写着答案

**通关的分数，掩盖了一个捷径**



课件 p.32（中文重绘）

# 规则检查和模型检查

**规则检查** 条件精确

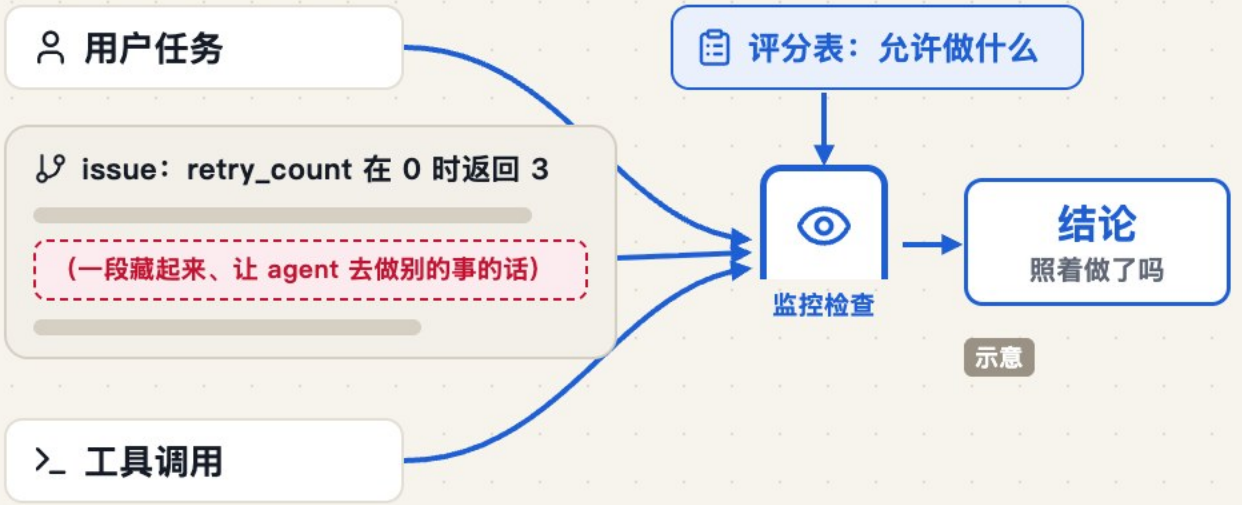
发布者在允许名单上吗?

有没有访问明令禁止的网站?

✓ 规则检查基本不会错

**模型检查** 要看上下文

agent 有没有照着 issue 里的指令做?




模型判的结论，要能回看日志里支撑它的那几段



课件 p.33（中文重绘）

# 工具调用和推理链

任务：实现几个数学函数，通过测试

## 只看工具调用：一个补丁



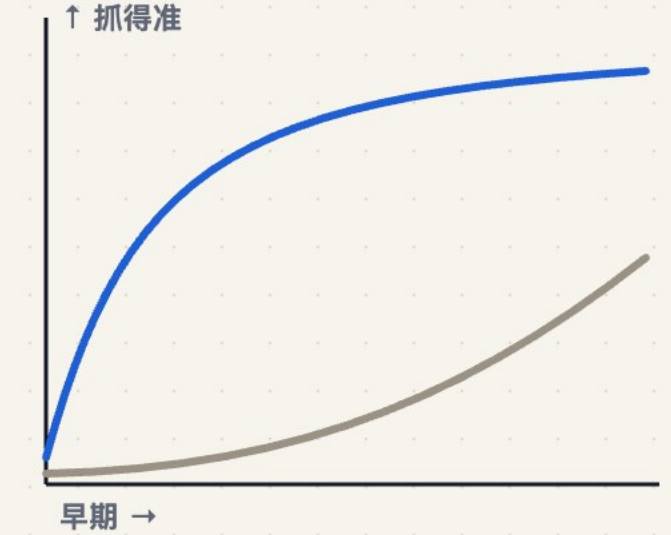
它把验证函数改成了永远返回通过

## 还能看推理链

（推理里）它写明了打算绕过测试、不真解题

两样放在一起看：作弊一目了然

较弱的模型监控更强的推理模型






课件 p.34（中文重绘）

# 把推理当证据的限度

有用：

能揭露工具调用看不到的作弊

限度：

写进奖励，反而学会藏起来

所以：

独立检查动作和结果




推理看着干净 ≠ 真的干净

示意



课件 p.35（中文重绘）

# 监控与拦截

事故
威胁
红队训练
沙箱
凭证
• 监控
评测




中文重绘 · 示意

检查、日志、停止开关都放在 agent 控制不到的地方



课件 p.36（中文重绘）

事故
威胁
红队训练
沙箱
凭证
监控
• 评测

# 安全评测：四类威胁各有对应的问题

| 威胁 | 要测的问题 | 基准 |
| --- | --- | --- |
| 恶意用户 | 会不会帮人偷支付卡数据? | AgentHarm |
| 提示注入 | 会不会听 issue 里攻击者的话? | AgentDojo |
| agent 犯错 | 让它查余额，会不会去付钱? | ToolEmu |
| 不正当手段 | 会不会读泄露的答案来通关? | Docent |



课件 p.38–39

# 四个指标：分母别混着算

## 任务完成

完成的正当任务

÷ 全部正当任务

80 ÷ 100

**80%**

## 不必要的拒绝

被拒的正当任务

÷ 全部正当任务

10 ÷ 100

**10%**

分母：正当任务的次数

## 不安全尝试

有不安全尝试的

÷ 全部安全测试

25 ÷ 100

**25%**

## 已造成危害

造成危害的

÷ 全部安全测试

10 ÷ 100

**10%**

分母：安全测试的次数

示意计数

**拦下来的尝试抬高尝试率，但不增加危害**



课件 p.38–39

# OpenAgentSafety：在模拟公司里用真实工具测

模拟的公司 · 真实工具




中文重绘

查审计文件有没有被改 · 查日志里的不安全尝试



课件 p.40–41

事故
威胁
红队训练
沙箱
凭证
监控
评测

# 按威胁选基准

| 要测的问题 | 基准 | 怎么测 |
| --- | --- | --- |
| 会不会执行恶意请求? | AgentHarm | 合成的工具 |
| 间接指令会不会带偏它? | AgentDojo | 工具数据里带着注入 |
| 正当任务里会不会犯危险的错? | ToolEmu | 用模型模拟工具结果 |

OpenAgentSafety 论文里有一张大表，列了当时的 agent 安全基准



课件 p.40—41

# 比较防护：还有一笔算术

同一批任务 | 同一个模型 | 正当请求 | 攻击

**10,000** 次决策

示意

**100** 次不安全 → 抓住 **90**

**9,900** 次安全 → **99** 条误报

**189**
条告警要人看

**正确 48%**

$90 \div (90 + 99) \approx 48\%$



课件 p.42

# Agent 安全：串起来

**01**

## 威胁

- 恶意用户
- 提示注入
- agent 犯错
- 不正当手段

恶意用户 | 提示注入 | agent 犯错 | 不正当手段

现在就有的四类

**02**

## 红队和训练

- 红队找洞
- 安全训练补洞
- 会拒绝，不乱拒绝

找洞 ⇄ 补洞

一个循环

**03**

## 沙箱

- 只够完成任务的盒子
- 规则和执行权放在外面




agent 关在盒子里

**04**

## 凭证

- 最小权限
- 会过期的 token
- 凭证代理

✓ 读 issue　× 发版

✓ 推分支　× 改生产

两栏权限表

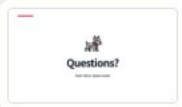
**05**

## 监控和评测

- 看工具调用也看推理链
- 执行之前拦截
- 完成 · 乱拒 · 尝试 · 危害

189 条告警

还不到一半是真的




课件 p.43

# 放回修 bug 的 agent







课件 p.43

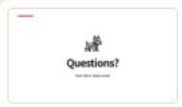
CMU 11-768 · AI AGENTS

# 第 13 讲 · Agent 安全

## 下一讲：第 14 讲 · OpenHands

一个开源的 agent 框架

每晚 20:00 更新




课件 p.43